

SAP SECURITY ADMINISTRATION, OPERATIONS & TROUBLESHOOTING

Chapter 5 – SAP Security Hardening, Performance & Best Practices

Q244. What is SAP Security Hardening?

Interviewer's Objective

The interviewer wants to assess whether you understand SAP Security beyond roles and authorizations.

Executive Answer

SAP Security Hardening is the process of strengthening the SAP landscape by reducing security vulnerabilities, minimizing attack surfaces, and implementing preventive controls.

It includes:

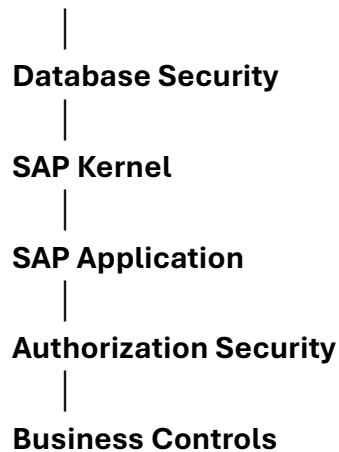
- Secure system configuration
- Strong authentication
- Password policies
- Secure RFC communication
- Client security
- Profile parameter configuration
- Patch management
- Network security
- Audit logging
- Continuous monitoring

The objective is to protect SAP systems from unauthorized access, cyberattacks, and internal misuse while maintaining business availability.

Security Hardening Layers

Network Security

Operating System



Q245. What are SAP Security Profile Parameters?

Executive Answer

Profile Parameters are SAP system settings that control system-wide security behavior.

Examples include:

Parameter	Purpose
login/min_password_lng	Minimum password length
login/fails_to_user_lock	Failed logon attempts before lock
login/password_expiration_time	Password expiry
login/password_history_size	Password history
auth/no_check_in_some_cases	Authorization behavior
login/disable_multi_gui_login	Prevent multiple GUI sessions

These parameters are maintained by the Basis team, but Security should review them to ensure compliance with organizational security standards.

Q246. Explain SAP Password Policy.

Executive Answer

A strong SAP password policy should include:

- **Minimum password length**
- **Complexity requirements**
- **Password history**
- **Expiration period**
- **Account lockout after failed attempts**
- **Password reset controls**
- **Restricted use of default passwords**

The policy should align with organizational cybersecurity standards and applicable regulatory requirements.

Q247. Explain Client Security.

Very common interview question.

Executive Answer

SAP clients should be secured to prevent unauthorized configuration changes and cross-client risks.

Best practices include:

- **Restrict SCC4 changes**
- **Protect client settings**
- **Limit client administration**
- **Disable unnecessary client copying**
- **Separate Development, QA, and Production**
- **Monitor client-independent changes**

Production clients should have strict controls over configuration and administrative activities.

Q248. What is SAP Security Patch Day?

Executive Answer

SAP releases monthly security updates through SAP Security Patch Day.

These updates address:

- **Newly identified vulnerabilities**
- **Critical security flaws**
- **Authentication issues**
- **Remote code execution risks**
- **Privilege escalation vulnerabilities**

Organizations should:

- **Review released security notes.**
- **Assess business impact.**
- **Test patches in non-production environments.**
- **Deploy approved fixes through change management.**

Timely patching significantly reduces security exposure.

Q249. Explain SAP Notes from a Security Perspective.

Executive Answer

SAP Notes provide official corrections, enhancements, and security recommendations.

From a security perspective, they are used to:

- **Resolve vulnerabilities**
- **Apply security fixes**
- **Update authorization behavior**
- **Improve system stability**
- **Maintain compliance**

Critical security notes should be prioritized based on risk assessment and tested before production deployment.

Q250. What is Vulnerability Management in SAP?

Executive Answer

SAP Vulnerability Management is the continuous process of identifying, assessing, prioritizing, remediating, and monitoring security weaknesses within the SAP landscape.

Typical activities include:

- **Reviewing SAP Security Notes**
- **Security scanning**
- **Patch management**
- **Configuration reviews**
- **Penetration testing**
- **Risk assessments**
- **Compliance validation**

Security is an ongoing process rather than a one-time activity.

Q251. Explain Secure RFC Configuration.

Executive Answer

Secure RFC configuration includes:

- **Dedicated RFC technical users**
- **Principle of Least Privilege**
- **SNC encryption**
- **Password management**
- **Trusted RFC review**
- **Restricting unnecessary RFC destinations**
- **Periodic access review**
- **Audit logging**

RFC connections should never be configured with excessive authorizations.

Q252. Explain SAP Kernel Security.

Executive Answer

The SAP Kernel is the core runtime component of the SAP application server.

Security considerations include:

- **Keeping the kernel up to date**
- **Applying supported patch levels**
- **Monitoring kernel vulnerabilities**
- **Restricting operating system access**
- **Protecting executable files**
- **Following SAP hardening recommendations**

Kernel updates should follow testing and formal change management procedures.

Q253. What is the Principle of Least Privilege?

One of the most common executive interview questions.

Executive Answer

The Principle of Least Privilege means users, administrators, and technical accounts should receive only the minimum access required to perform their assigned responsibilities.

Benefits include:

- **Reduced attack surface**
- **Lower risk of fraud**
- **Better compliance**
- **Easier audits**
- **Reduced impact of compromised accounts**

Least Privilege should be applied consistently across:

- **Business users**

- **SAP administrators**
 - **RFC users**
 - **Background users**
 - **Emergency access**
-

Q254. Explain Segregation of Duties from a Security Architecture Perspective.

Executive Answer

Segregation of Duties is a governance principle that prevents a single individual from controlling an entire critical business process.

Examples:

- **Creating and paying a vendor**
- **Creating and approving purchase orders**
- **Posting and approving financial journals**

Rather than focusing only on technical conflicts, architects evaluate:

- **Business risk**
- **Process design**
- **Compensating controls**
- **Operational requirements**

SAP GRC automates the detection and management of these conflicts.

Q255. Explain Security Baseline Reviews.

Executive Answer

A Security Baseline Review evaluates whether an SAP landscape complies with defined security standards.

Typical review areas include:

- **User administration**
- **Role quality**

- **Technical users**
- **RFC security**
- **Password policy**
- **Audit logging**
- **Security parameters**
- **Patch levels**
- **SoD compliance**
- **Firefighter governance**

Baseline reviews are usually performed periodically or before major audits.

Q256. How do you optimize SAP Security Performance?

Executive Answer

Security should not negatively affect system performance.

Optimization techniques include:

- **Efficient role design**
- **Reducing duplicate roles**
- **Optimizing authorization checks**
- **Maintaining SU24 proposals**
- **Removing obsolete users**
- **Archiving historical logs**
- **Monitoring authorization trace usage**
- **Optimizing background jobs**

Security controls should be effective while minimizing operational overhead.

Q257. Real Production Scenario

Interviewer

"Your company receives a Critical SAP Security Note addressing a remote code execution vulnerability. What would you do?"

Executive Answer

I would treat it as a high-priority security event.

- 1. Review the SAP Security Note to understand affected components and severity.**
 - 2. Determine whether our landscape is impacted.**
 - 3. Coordinate with Basis, Infrastructure, and Application teams.**
 - 4. Assess the business risk and potential exposure.**
 - 5. Test the patch in Development and QA environments.**
 - 6. Obtain change approvals according to organizational processes.**
 - 7. Deploy the patch to Production during an approved maintenance window.**
 - 8. Validate system functionality after deployment.**
 - 9. Document remediation and retain evidence for audit purposes.**
-

Q258. Executive Interview Scenario

Interviewer

"As SAP Security Lead, what would be your top priorities during your first 90 days?"

Executive Answer

My first 90-day plan would focus on strengthening governance while minimizing operational risk.

First 30 Days

- Assess role landscape**
- Review privileged users**
- Evaluate SoD risks**
- Review technical users**
- Understand business processes**

Days 31–60

- **Improve role design**
- **Strengthen GRC controls**
- **Review audit findings**
- **Assess security parameters**
- **Review patch status**

Days 61–90

- **Establish security KPIs**
- **Improve access review processes**
- **Optimize emergency access governance**
- **Standardize documentation**
- **Develop a continuous improvement roadmap**

Rapid-Fire Questions

What transaction maintains client settings?

Answer: SCC4

Which transaction maintains profile parameters?

Answer: RZ10 (profile maintenance) and RZ11 (display/change dynamic profile parameters where appropriate).

What is the purpose of SAP Security Patch Day?

Answer: To release monthly security fixes addressing vulnerabilities and security defects.

What is the Principle of Least Privilege?

Answer: Grant users only the minimum access required to perform their job responsibilities.

Who should review SAP Security Notes?

Answer: Security, Basis, Infrastructure, and Application teams should jointly evaluate relevant notes and coordinate implementation.

Architect's Insight

One of the strongest statements you can make in an interview is:

"SAP Security is not just about preventing unauthorized access. It is about enabling the business securely through governance, proactive risk management, resilient system design, and continuous monitoring."

That reflects the mindset expected from a Security Architect or SAP Security Lead.

Chapter Summary

You should now be comfortable discussing:

- **SAP Security Hardening**
- **Profile Parameters**
- **Password Policies**
- **Client Security**
- **SAP Security Patch Day**
- **SAP Notes**
- **Vulnerability Management**
- **Secure RFC configuration**
- **Kernel Security**
- **Principle of Least Privilege**
- **Security Baseline Reviews**
- **Performance optimization**
- **Executive security strategy**

End of CATEGORY 7 – SAP Security Administration, Operations & Troubleshooting

By now, your handbook covers:

- **SAP GRC Access Control (ARA, ARM, EAM, BRM, MSMP, Rule Sets)**
- **SAP S/4HANA Security**
- **SAP Fiori Security**
- **SAP Identity Management (SAP IDM)**
- **SAP Security Operations**
- **Audit & Compliance**
- **Hardening & Security Architecture**

Next Major Category – SAP BTP Security, Cloud Identity & RISE with SAP

Given today's market and your target roles, this category is extremely important. It will cover:

- **SAP BTP Security Architecture**
- **XSUAA**
- **OAuth 2.0 & JWT**
- **SAP Cloud Identity Services**
- **IAS & IPS integration with BTP**
- **Cloud Connector**
- **Destination Service**
- **Authorization Collections**
- **Trust Configuration**
- **Principal Propagation**
- **SAP Build & CAP security**
- **RISE with SAP security model**
- **Real-world migration and architect-level interview scenarios**

This is one of the fastest-growing skill areas for senior SAP Security professionals and is increasingly expected in modern SAP transformation programs.